

Security and Governance Note

Project 1: EU AI Act Compliance Advisor. Retrieval-augmented generation on Azure.

Cindy Moncada | AI Solutions Architect

This note records the security and governance controls applied to the reference implementation, the reasoning behind each, and its current status. This is a reference implementation, not a production system; the final section states plainly what is deliberately not yet in place.

1. Identity and access: managed identity over keys

Control: Both service-to-service connections use managed identity rather than shared API keys. The search service reads storage as itself; the Foundry project reads the search index as itself.

Rationale: Keys are long-lived shared secrets that can leak, get copied into code, and need rotating. Managed identities are issued and controlled by Azure, carry no secret to expose, and are removed automatically if the resource is deleted. This is Microsoft's recommended posture.

Status: Implemented.

2. Least-privilege roles

Control: Each identity holds only the minimum role it needs. The search service has Storage Blob Data Reader on the storage account (read the source documents, nothing more). The Foundry project has Search Index Data Reader on the search service (query the index, not manage it).

Rationale: Read-only, narrowly scoped roles mean that a compromise of either identity cannot write, delete, or reconfigure anything. This is the least-privilege principle, and it is the kind of concrete control regulated-industry reviewers look for.

Status: Implemented.

3. Data residency

Control: All components (project, models, search, storage) are deployed in Sweden Central, inside the Azure EU Data Boundary, so data at rest stays in the EU geography.

Rationale: A tool that advises on the EU AI Act should itself keep data in the EU. The region was chosen for residency, not convenience.

Status: Implemented for the region and for data at rest. Interim caveat: the chat model currently runs on a Global Standard deployment while an EU Data Zone Standard quota request is pending, which means inference processing can route outside the EU even though storage does not. Production would require the EU Data Zone deployment. (See design-decisions note, item 4.)

4. Grounding and output controls

Control: The agent's system instructions require it to answer only from the connected EU AI Act source, cite the specific articles or recitals it relies on, state plainly when the source does not cover a question, and note that it provides regulatory information, not legal advice.

Rationale: These instructions are the first line of defense against hallucination. Grounding plus citation makes each answer checkable against the source; the refuse-when-uncovered instruction stops the model inventing law; the not-legal-advice line sets scope honestly for a compliance context.

Status: Implemented and tested. Verified that the agent returns article-level citations on an in-scope question (Article 6(1), Annexes II and III). Recommended additional check: confirm it declines an out-of-scope question.

5. Reducing the data-egress surface

Control: The web search tool (Grounding with Bing) was deliberately left disabled.

Rationale: The portal itself warns that this tool sends data outside the Azure compliance boundary. Enabling it would contradict the residency posture and introduce an uncontrolled external source into a tool that must ground only on the official text. Retrieval is restricted to the curated index.

Status: Implemented (disabled by choice).

6. Deliberately out of scope for this reference implementation

The following are not implemented, by scope, and are the natural content of the governed-deployment project (Project 3):

Network lockdown: storage and search sit on public endpoints so the managed ingestion could run; production would place them behind private endpoints and a virtual network.

PII redaction: no inbound or outbound PII detection or masking is in place.

Audit logging: agent queries and retrievals are not yet captured to an audit trail.

Content safety: no content-filtering layer beyond the model's built-in safety.

Human-in-the-loop review: none, which is appropriate for an informational advisor and would be revisited if the tool's scope grew.